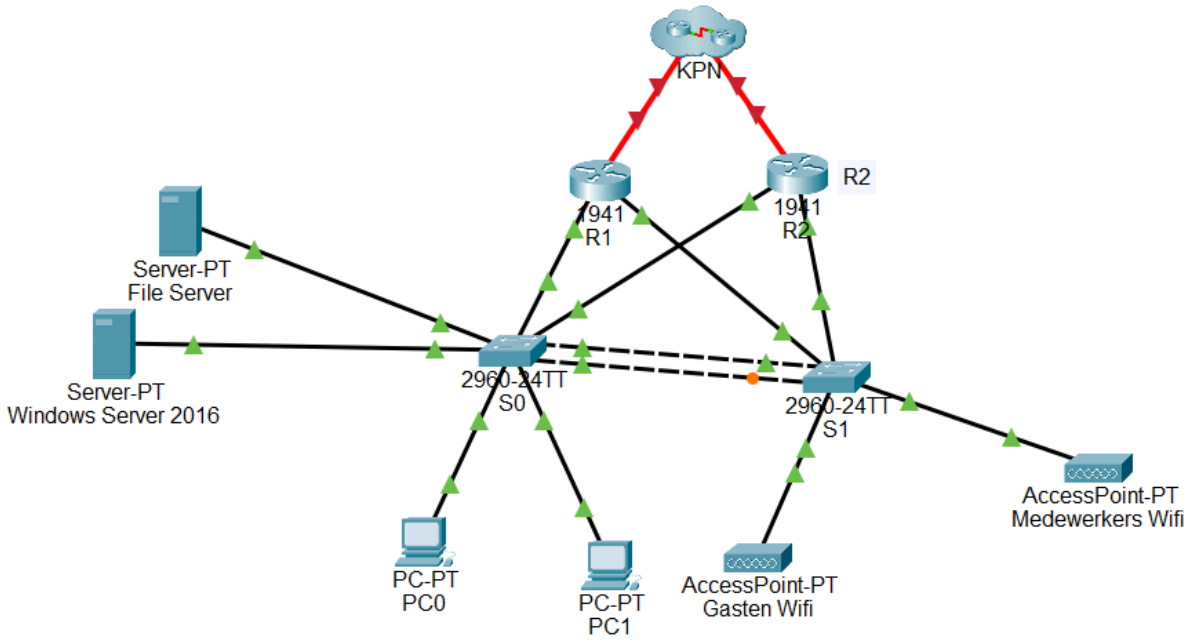
Template Risicoanalyse Vanguard

Deze risicoanalyse is bedoeld voor studenten die de onveilige netwerkconfiguratie onderzoeken zoals beschreven in de Cisco Packet Tracer infrastructuur. Het doel is om bewustwording te creëren van bekende kwetsbaarheden in laag 2 en laag 3, de mogelijke impact in kaart te brengen, en gepaste mitigatiestrategieën voor te stellen.



1. Voorblad

Datum analyse: 03/03/2026
Naam student: Viresh Sheoratan
Klas: 500857506

Naam student: Muazma Anwar
Klas: 500900797

Versie document: V3

Beschrijving omgeving:

(Geef een korte samenvatting van de netwerkopstelling: aantal routers, switches, VLANs, DHCP, HSRP, OSPF, servers, IT en OT componenten, enz.)

De netwerkopstelling van Vanguard bestaat uit:

Apparaten

- 2 routers: R1 en R2
- 2 switches: S0 en S1
- 2 servers: File Server en Windows Server 2016
- 2 PC's: PC0 en PC1
- 2 access points: Medewerkers Wifi en Gasten Wifi
- 2 KPN verbindingen, 1 per router

Netwerkconfiguratie

- 2 VLANs: VLAN 10 (servers, 192.168.10.0/24) en VLAN 20 (PC's, 192.168.20.0/24)
- Router-on-a-stick: beide routers gebruiken subinterfaces (Gig0/0.10 en Gig0/0.20) met dot1Q encapsulation
- DHCP: beide routers zijn DHCP-server voor VLAN 10 en VLAN 20
- HSRP: alleen geconfigureerd op R2 voor VLAN 20, virtual IP 192.168.20.1
- OSPF: process 1 actief op beide routers in Area 0
- EtherChannel: PAgP tussen S0 en S1 via Port-channel 1
- VTP: S0 = Server, S1 = Client

Werkwijze risicoanalyse

Ik ben begonnen met zelf testen: ipconfig, ping, tracert en telnet uitvoeren op de PC's en servers om de netwerktopologie en connectiviteit te achterhalen.
Daarna heeft de docent aangeraden om de volgende protocollen en technologieën systematisch te onderzoeken
uit de week 2 slide: CDP, LLDP, SNMP, STP, DTP, VLAN, VTP, BPDU, EtherChannel, DOT1Q, Telnet, SSH, HSRP, OSPF, UDLD, Routing, HTTP en DHCP.
Met behulp van mijn samenvattingen uit de lessen en chatgpt heb ik per protocol uitgezocht welke show commands ik nodig had om kwetsbaarheden te identificeren. De resultaten heb ik eerst gedocumenteerd en daarna deze risicoanalyse gemaakt.

bevindingen tijdens testen

2. Risicoanalyse Matrix

Nr	Component/Service	Kwetsbaarheid / Foutconfiguratie	Mogelijke Impact	Waarschijnlijkheid	Impactniveau	Risicoscore	Mitigatie / Advies
1	CDP - R1, R2, S0, S1	CDP staat aan op alle apparaten. Lekt IP-adressen, IOS-versie (15.0(2)SE4), platform (2960/C1900) en poort info	Aanvaller kan volledige netwerktopologie achterhalen	4	3	12	no cdp run globaal, of no cdp enable per interface
2	LLDP - R1, R2, S0, S	LLDP staat actief op alle apparaten, toont neighbors met platform en poortinfo	Dubbele informatielekkage naast CDP	4	3	12	no lldp run globaal uitschakelen
3	STP - S0, S1	PortFast BPDU Guard Default = disabled, Root Guard = disabled, Loopguard = disabled op beide switches	Aanvaller kan eigen switch aansluiten en root bridge overnemen, netwerk loops veroorzaken	3	5	15	spanning-tree portfast bpduguard default, spanning-tree guard root op trunk poorten
4	DTP -S1	Fa0/6 staat op mode auto (DTP negotiation actief), vormt automatisch trunk. Ook fa0/5, fa0/9-24, gig0/1 en gig0/2 staan op auto	Aanvaller kan via DTP een trunk opzetten en alle VLAN-verkeer onderscheppen (VLAN hopping)	4	5	20	switchport mode access + switchport nonegotiate op alle access poorten
5	VLAN - S0, S1	Veel ongebruikte poorten zitten in VLAN 1 (default) en staan nog aan	Geen segmentatie, onbevoegde toegang via	3	4	12	Ongebruikte poorten in apart VLAN plaatsen + shutdown

			ongebruikte poorten				
6	VTP - S0, S1	VTP domain "LAB" zonder password ("The VTP password is not configured"). S0=Server, S1=Client. VTP Pruning disabled	Aanvaller kan switch aansluiten met hogere revision number en volledige VLAN-database overschrijven/wissen	3	5	15	vtp password sterk-wachtwoord instellen, of vtp mode transparent gebruiken
7	BPDU Guard - S0, S1	show running-config | include bpduguard toont niets. Geen BPDU Guard geconfigureerd op enige poort. show running-config | include guard liet ook inlog gegevens zien: username Vanguard password Vanguard	Aanvaller kan BPDU-berichten sturen om STP-topologie te manipuleren. Wachtwoord Vanguard in plain text leesbaar	3	5	15	spanning-tree portfast bpduguard default globaal. service password-encryption activeren
8	EtherChannel - S0-S1	PAgP EtherChannel: S0 Fa0/8 = stand-alone (I), S1 Fa0/7 = desirable (D). Mismatch in bundeling. Load-balancing = src-mac (standaard, niet optimaal)	Verminderde redundantie en bandbreedte, niet alle links actief	2	3	6	EtherChannel opnieuw configureren zodat alle poorten (P) status krijgen. Overweeg port-channel load-balance src-dst-ip
9	Trunking/DOT1Q - S0, S1	Native VLAN = 1 op alle trunk poorten (Po1, Fa0/1, Fa0/6). VLANs allowed on trunk: 1-1005 (veel meer dan nodig)	VLAN hopping via double-tagging aanval op native VLAN 1	3	5	15	Native VLAN wijzigen naar ongebruikt VLAN: switchport trunk native vlan 999. Trunk beperken: switchport trunk allowed vlan 10,20

10	Telnet - R1	Telnet actief op 192.168.20.2, plain text protocol. Geen transport input ssh geconfigureerd op alle apparaten. S0 vty 0-4 en 5-15 met login zonder "local". Console poort zonder password	Wachtwoorden en commando's kunnen worden afgeluisterd op het netwerk. Fysieke toegang = directe CLI toegang	4	5	20	Vervang Telnet door SSH: transport input ssh op VTY lines. Console password instellen
11	SSH - R1, R2, S0, S1	SSH version 1 geconfigureerd op alle apparaten (ip ssh version 1). SSH v1 heeft bekende kwetsbaarheden	Man-in-the-middle aanvallen op SSH-sessies, sessie kan onderschept worden	3	4	12	Upgrade naar ip ssh version 2 op alle apparaten
12	HSRP - R1, R2	HSRP alleen geconfigureerd op R2 voor VLAN 20 (virtual IP 192.168.20.1). R1 heeft geen HSRP. Geen HSRP voor VLAN 10. Geen authenticatie. Preemption disabled. Standby router = unknown	Geen failover: als R2 uitvalt werkt gateway 192.168.20.1 niet meer. Aanvaller kan HSRP spoofing doen zonder authenticatie. Servers (VLAN 10) hebben geen gateway redundantie	3	4	12	HSRP ook op R1 configureren. HSRP voor VLAN 10 toevoegen. standby 20 authentication md5 key-string ww. standby 20 preempt inschakelen
13	OSPF - R1, R2	OSPF actief in Area 0, geen authenticatie ("Area has no authentication"). Neighbor state = INIT/DROTHER (niet FULL).	Aanvaller kan valse routes injecteren. OSPF adjacency niet	3	5	15	OSPF authenticatie instellen: area 0 authentication message-digest.

		WAN-links (10.1.1.0, 10.1.2.0) DOWN	volledig = routing werkt niet correct				Per interface: ip ospf message-digest-key 1 md5 ww
14	UDLD - S0, S1	UDLD niet ondersteund (show udld = Invalid input)	Unidirectionele links kunnen onopgemerkt blijven en loops of black holes veroorzaken	2	3	6	In productieomgeving: udld enable of udld aggressive
15	Routing - R1, R2	Geen default route ingesteld ("Gateway of last resort is not set"), alleen connected routes zichtbaar. Geen static routes. WAN-interfaces DOWN	Geen internetverbinding, verkeer tussen subnetten faalt	5	5	25	Default route instellen: ip route 0.0.0.0 0.0.0.0 next-hop. default-information originate in OSPF
16	DHCP - R1, R2	Beide routers zijn DHCP-server voor dezelfde netwerken (conflict). R1 DHCP incompleet: geen default-router, geen excluded-address. R1 heeft IP's uitgedeeld zonder gateway (verklaart PC gateway 0.0.0.0). Geen DHCP snooping op switches	DHCP spoofing: aanvaller kan valse DHCP-server opzetten. PC's krijgen geen gateway van R1. IP-conflicten mogelijk	3	5	15	R1 DHCP fixen of uitschakelen. ip dhcp snooping inschakelen op switches. Trusted ports instellen
17	AP - Medewerkers + Gasten	Encryption type = disabled op beide access points. Geen WEP/WPA/WPA2, geen wachtwoord	Iedereen kan verbinden met het netwerk en al het draadloze verkeer afluisteren	5	5	25	WPA2-PSK of WPA2-Enterprise instellen met sterk wachtwoord

18	Wachtwoorden - R1, R2, S0, S1	enable password cisco (zwak standaard wachtwoord, plain text). no service password-encryption bevestigd. Username Vanguard met password Vanguard (plain text). enable password i.p.v. enable secret	Wachtwoorden leesbaar in configuratie. Zwak wachtwoord makkelijk te raden	4	4	16	Vervang door enable secret. service password-encryption activeren. Sterke wachtwoorden gebruiken
19	Default Gateway - PC0, PC1	Default gateway = 0.0.0.0 op beide PC's. DHCP van R1 geeft geen gateway mee	PC's kunnen niet communiceren buiten hun subnet	5	4	20	Default gateway instellen op 192.168.20.1 (HSRP virtual IP), of DHCP op R1 fixen
20	Configure Terminal - R1, R2, S0, S1	Vanuit enable mode (password "cisco") kan direct conf t worden uitgevoerd. Geen extra authenticatie of autorisatie vereist voor configuratiewijzigingen	Aanvaller met enable toegang kan volledige configuratie wijzigen: VLANs verwijderen, routes aanpassen, wachtwoorden wijzigen, interfaces uitschakelen, backdoor accounts aanmaken	4	5	20	Sterk enable secret instellen. AAA autorisatie configureren met privilege levels. login local met sterke wachtwoorden. Logging van configuratiewijzigingen inschakelen

3. Scoringsmodel voor Risico’s

Gebruik onderstaand model om per risico de score in te vullen:

Waarschijnlijkheid (kans dat het risico optreedt):
- 1 = Zeer laag
- 2 = Laag
- 3 = Gemiddeld
- 4 = Hoog
- 5 = Zeer hoog

Impactniveau (schade als het risico optreedt):
- 1 = Verwaarloosbaar
- 2 = Laag (beperkte impact)
- 3 = Gemiddeld (diensten tijdelijk onderbroken)
- 4 = Hoog (meerdere systemen beïnvloed)
- 5 = Kritiek (netwerk plat, datalek)

Risicoscore = Waarschijnlijkheid × Impactniveau
> Gebruik deze score om te prioriteren. Bijvoorbeeld:
> - 1–5 = Laag risico
> - 6–12 = Matig risico
> - 13–25 = Hoog risico

4. Top 5 Kritieke Risico’s

1. **Risico:** Wi-Fi zonder encryptie, Encryption disabled op beide access points (Medewerkers + Gasten), geen WPA/WPA2, geen wachtwoord
    - **Impact**: Iedereen binnen bereik kan verbinden met het bedrijfsnetwerk en al het draadloze verkeer afluisteren, inclusief gevoelige bedrijfsdata en inloggegevens (score: 5×5 = 25)
    - **Oplossing**: WPA2-PSK of WPA2-Enterprise configureren op beide access points met een sterk wachtwoord. Aparte SSID's en VLANs voor medewerkers en gasten
2. **Risico**: Geen default route / routing faalt, Gateway of last resort is not set op beide routers. Alleen connected routes zichtbaar, geen OSPF-routes (OSPF neighbor state = INIT/DROTHER). WAN-interfaces naar KPN liggen
    - **Impact**: Geen internetverbinding mogelijk. Verkeer tussen subnetten faalt. Het volledige netwerk is geïsoleerd van de buitenwereld (score: 5×5 = 25)
    - **Oplossing**: Default route instellen: ip route 0.0.0.0 0.0.0.0 <KPN next-hop>. OSPF adjacency troubleshooten zodat state FULL wordt. default-information originate in OSPF configureren
3. **Risico**: DTP actief op access poorten, S1 Fa0/6 staat op mode auto, en ook fa0/5, fa0/9-24, gig0/1, gig0/2 staan op dynamic auto. DTP negotiation vormt automatisch trunk verbindingen
    - **Impact**: Een aanvaller kan een apparaat aansluiten dat DTP desirable stuurt, automatisch een trunk opzetten en al het VLAN-verkeer onderscheppen inclusief het server-VLAN (VLAN hopping) (score: 4×5 = 20)
    - **Oplossing**: switchport mode access en switchport nonegotiate instellen op alle access poorten. Alleen bewust geconfigureerde trunk poorten toestaan
4. **Risico**: Telnet in gebruik (plain text), Telnet actief op R1 (192.168.20.2), geen transport input ssh geconfigureerd op alle apparaten. SSH version 1 in gebruik. Console poort zonder password. S0 vty lines met login zonder "local"

- **Impact**: Alle inloggegevens en commando's worden onversleuteld over het netwerk verstuurd en kunnen worden afgeluisterd. Fysieke toegang geeft directe CLI toegang zonder authenticatie (score: 4×5 = 20)

- **Oplossing**: transport input ssh op alle VTY lines. Upgrade naar ip ssh version 2. Console password instellen. login local op alle VTY lines

5. **Risico**: PC's zonder default gateway, Default gateway = 0.0.0.0 op PC0 en PC1. Veroorzaakt door incomplete DHCP-configuratie op R1 (geen default-router ingesteld). R1 deelt wel IP-adressen uit maar zonder gateway

    - **Impact**: PC's kunnen niet communiceren buiten hun eigen subnet. Pings naar servers (192.168.10.x) falen. Gebruikers hebben geen toegang tot bedrijfsapplicaties en internet (score: 5×4 = 20)

    - **Oplossing**: R1 DHCP fixen: default-router 192.168.20.1 toevoegen aan pool VLAN20. Of R1 DHCP uitschakelen en alleen R2 als DHCP-server gebruiken. PC's default gateway instellen op 192.168.20.1 (HSRP virtual IP)

5. Hardening Checklist (Optioneel)

Nr	Maatregel	Status (✓/✗)	Opmerkingen
1	CDP uitschakelen (no cdp run)	✗	Risico 1: staat aan op R1, R2, S0, S1
2	LLDP uitschakelen (no lldp run)	✗	Risico 2: staat actief op R1, R2, S0, S1
3	BPDU Guard en Root Guard inschakelen	✗	Risico 3: alles disabled op S0 en S1
4	DTP uitschakelen (switchport nonegotiate)	✗	Risico 4: S1 Fa0/6 en veel andere poorten op mode auto
5	Ongebruikte poorten in apart VLAN + shutdown	✗	Risico 5: veel poorten actief in VLAN 1
6	VTP password instellen	✗	Risico 6: "The VTP password is not configured"
7	service password-encryption activeren	✗	Risico 7: username Vanguard password 0 Vanguard in plain text
8	EtherChannel mismatch fixen	✗	Risico 8: S0 Fa0/8 stand-alone, S1 Fa0/7 down
9	Native VLAN wijzigen + trunk VLANs beperken	✗	Risico 9: native VLAN = 1, allowed 1-1005
10	Telnet uitschakelen (transport input ssh)	✗	Risico 10: Telnet actief, console zonder password
11	SSH upgraden naar version 2	✗	Risico 11: SSH version 1 op alle apparaten
12	HSRP op R1 configureren + authenticatie + VLAN 10	✗	Risico 12: alleen op R2 VLAN 20, geen auth, geen preempt
13	OSPF authenticatie configureren	✗	Risico 13: "Area has no authentication", state INIT
14	Default route instellen op routers	✗	Risico 15: "Gateway of last resort is not set"

15	DHCP snooping inschakelen + R1 DHCP fixen	✗	Risico 16: geen snooping, R1 geen default-router
16	WPA2 instellen op beide access points	✗	Risico 17: encryption disabled
17	Vervang enable password door enable secret	✗	Risico 18: enable password cisco plain text
18	Default gateway instellen op PC's	✗	Risico 19: gateway = 0.0.0.0
19	login local op alle VTY lines	✗	
20	Enable password beschermen tegen conf t toegang	✗	Vanuit enable mode (password "cisco") kan een aanvaller direct conf t gebruiken om de volledige configuratie te wijzigen, VLANs te verwijderen, routes aan te passen.

6. Conclusie / Refectie

Wat zijn volgens jou de grootste risico’s in deze configuratie?

De twee grootste risico's zijn de Wi-Fi access points zonder encryptie en het ontbreken van een default route op de routers.

De access points staan helemaal open, geen wachtwoord, geen encryptie. Iedereen die binnen bereik is kan verbinden met het bedrijfsnetwerk en al het verkeer meelezen. Dit is het makkelijkste aanvalspunt omdat je er geen technische kennis voor nodig hebt.

Het ontbreken van een default route zorgt ervoor dat het netwerk eigenlijk niet functioneert zoals het hoort. De PC's kunnen niet bij de servers komen, er is geen internetverbinding, en OSPF werkt niet goed (state INIT in plaats van FULL). Het netwerk is dus niet alleen onveilig, maar ook kapot.

Daarnaast is Telnet een groot probleem. Alle wachtwoorden en commando's worden onversleuteld over het netwerk verstuurd.
En het enable wachtwoord is "cisco", een van de meest bekende standaard wachtwoorden. Samen met het account "Vanguard" met wachtwoord "Vanguard" in plain text betekent dit dat een aanvaller vrij snel volledige controle over het netwerk kan krijgen.

Welke onderdelen zouden als eerste gehard moeten worden en waarom?

Als eerste zou ik de Wi-Fi access points beveiligen met WPA2, omdat dit het laagste instapniveau heeft voor een aanvaller.

Daarna de wachtwoorden versterken: ‘enable secret’ in plaats van ‘enable password’, ‘service password-encryption’ aanzetten, en sterkere wachtwoorden kiezen dan "cisco" en "Vanguard".

Vervolgens Telnet uitschakelen en SSH version 2 afdwingen met ‘transport input ssh’. Hierna DTP uitschakelen op alle access poorten zodat een aanvaller geen trunk kan opzetten.

En als laatste de ongebruikte poorten op de switches uitzetten met ‘shutdown‘ en in een apart VLAN plaatsen, zo kan niemand zomaar een apparaat aansluiten.

Wat heb je geleerd over het belang van netwerksegmentatie, toegangscontrole en device hardening?

Ik heb geleerd dat netwerksegmentatie met VLANs alleen werkt als je het goed configureert. In deze omgeving zijn er wel VLANs aangemaakt (10 en 20), maar de

meeste poorten zitten nog in VLAN 1, DTP staat op auto, en de native VLAN is niet gewijzigd. Daardoor kan een aanvaller alsnog bij alle VLANs komen via VLAN hopping.

Bij toegangscontrole heb ik gezien hoe belangrijk het is om op alle niveaus te beveiligen. De console poort heeft geen wachtwoord, Telnet staat open en SSH draait op version 1. Een aanvaller heeft meerdere manieren om binnen te komen.

Device hardening gaat over alle kleine dingen die samen een groot verschil maken: CDP en LLDP uitzetten, BPDU Guard aanzetten, VTP password instellen, OSPF authenticatie configureren, DHCP snooping inschakelen. Geen van deze dingen was gedaan in deze omgeving. Ik heb geleerd dat je als beheerder niet alleen het netwerk moet laten werken, maar ook actief moet nadenken over hoe je het beschermt tegen aanvallen.